INCIDENT REPORT · REVISION 1.1 · ATTRIBUTION & REMEDIATION

Inside the Binance Hot-Wallet Breach

A compromised engineer's laptop gave North Korea's TraderTraitor unit the exchange's signing path. An Ethereum account-delegation feature then turned one wallet into a standing drain — emptying the very addresses Binance publishes as proof its customers are fully backed.

$6.36B
TOTAL STOLEN
(TRM LABS, 10 CHAINS)

~$2.4B
STILL BEYOND
ANY ISSUER'S REACH

DPRK
ATTRIBUTED TO NORTH KOREA
(FBI-CONFIRMED)

MECHANISM	Compromised DevOps laptop → service container → unauthorised withdrawal submissions; EIP-7702 delegation amplified the Ethereum losses
CHAINS TOUCHED	Ethereum, Bitcoin, Tron, XRP Ledger, Solana, Arbitrum, Optimism, Base, Avalanche, Polygon
STILL UNFROZEN	~$2.4B — 420,000+ ETH and 18,270 BTC held outside any freeze mechanism
CUSTOMER IMPACT	Deposits and withdrawals suspended since 29 Oct; ~90% of losses replenished; reopening targeted Sunday 1 Nov

Incident window
29 Oct 2026, 20:05 UTC onward

Revision 1.1
1 November 2026

Status
Attributed · remediation underway

Contents

1 Executive summary

2 What is confirmed, and what is only reported

3 Timeline of the incident

4 How the attack worked: access, then amplification

5 The money: estimates, freezes, and what is still loose

6 The reserve-backing problem

7 Response: Binance, issuers, DeFi, law enforcement

8 Market impact

9 Best practices

10 Resources to monitor

11 What to watch next

12 Methodology, sources, disclaimer

1 Executive summary

On the afternoon of Thursday, 29 October 2026, roughly **$6.36 billion** left Binance-controlled wallets across **ten blockchains**, most of it inside about twenty minutes. It is the largest cryptocurrency theft ever recorded — roughly four times the $1.5 billion Bybit heist of February 2025 — and it has been attributed with high confidence to **TraderTraitor**, the North Korean state unit also tracked as Lazarus and APT38. On 1 November the **FBI confirmed** North Korea's role and asked the DeFi community to block the relevant BTC, ETH and SOL addresses.

What revision 1.1 changes. The first edition of this report, written within hours of the event, named a leaked hot-wallet private key as the likely root cause and put the loss at $5.5–5.9B with no attribution. Both are now superseded. Binance's own investigation links the breach to a **compromised DevOps engineer's laptop** that gave access to a service container and allowed unauthorised withdrawal submissions — and states it found **no evidence of a leaked wallet private key**. Co-CEO Richard Teng was explicit that this was "not a single 'one-click' action" and that no individual had been blamed. Binance later disclosed "additional points of breach" still under investigation. The EIP-7702 delegation documented below was real and unprecedented in scale, but on current evidence it **amplified** the losses rather than causing the breach.

THE FINDING THAT MATTERS MOST

The attacker did not break cryptography and did not exploit a bug in Ethereum or in Binance's contract code. They obtained **operational access to the infrastructure that produces signatures** — via an engineer's workstation — and used it to submit withdrawals the exchange's own systems treated as legitimate. EIP-7702 was the mechanism that made one wallet repeatedly drainable, but the door opened upstream, in endpoint security and privileged access. Any exchange that hardens keys while leaving signing infrastructure reachable from a laptop carries the same exposure.

The drained wallets were also the ones Binance publishes in its monthly proof-of-reserves disclosure as backing customer assets; CoinDesk's review of Binance's own reserve data placed its ether backing about 6% short until the stolen assets were replaced. Binance has since set aside **$6.34 billion**, reported roughly **90%** of losses covered by 31 October, and declared ten assets — BTC, ETH, USDT, BNB, SOL, USDC, XRP, USD1, RLUSD and ZEC — **100% backed**, funded from company treasury, futures insurance reserves and the SAFU emergency fund. The residual shortfall sits in less liquid tokens being bought through market and OTC channels. Withdrawals, suspended since the evening of 29 October, are targeted to reopen on Sunday 1 November.

WHAT IS STILL NOT KNOWN

How the necessary EIP-7702 authorisations were obtained has not been publicly established. The "additional points of breach" have not been detailed. The loss figure remains Binance's own account rather than an audited number, and the new zero-knowledge reserve proof — 40 to 50 hours to generate — will not be verifiable by holders until roughly 3 November. Withdrawals have not yet actually resumed.

2 What is confirmed, and what is only reported

Three classes of claim circulate around this incident and they should not be mixed. Revision 1.1 moves several entries that were previously "reported" into "confirmed" — and moves the root cause in the opposite direction.

TABLE 1 — EPISTEMIC STATUS OF THE MAJOR CLAIMS

Claim	Detail	Status
Funds left Binance-controlled wallets	On-chain transfers from addresses Binance labels, corroborated by Etherscan, Arbiscan, Snowscan and multiple analytics firms.	**Confirmed.** On-chain, not disputable.
It was a hack, not a rebalancing	Binance confirmed the breach; co-CEO Yi He pledged to cover all losses from SAFU and company funds.	**Confirmed by Binance.**
Scale	TRM Labs: **$6.36B** across ten blockchains, most within ~20 minutes. Binance has set aside **$6.34B**. Earlier third-party estimates of $5.3–5.9B were gross tallies made within hours.	**Converged, not audited.** Two independent figures now bracket ~$6.3–6.4B.
Attribution	TRM Labs and Chainalysis attribute to **TraderTraitor** (Lazarus / APT38) with "high degree of confidence". **FBI confirmed** North Korea's role on 1 November and asked DeFi participants to block BTC, ETH and SOL addresses.	**Attributed.** Government-confirmed. This was "unattributed speculation" in revision 1.0.
Root cause	Binance links it to a **compromised DevOps engineer's laptop** reaching a service container, enabling unauthorised withdrawal submissions. Binance reports **no evidence of a leaked private key**, and later disclosed "additional points of breach".	**Company finding, still evolving.** Revision 1.0's "leaked Binance 14 key" is *withdrawn* as unestablished.
How the EIP-7702 authorisations were obtained	Candidates: misuse of legitimate signing access obtained via the compromised host, or another weakness in the signing path. Not established publicly.	**Unknown.** The central open question.
Customer funds covered	Binance: ~90% of stolen assets replenished; ten named assets 100% backed; remaining shortfall in illiquid tokens; losses absorbed by Binance, not users.	**Company statement, partly verifiable.** Reserve proof not yet independently checkable until ~3 Nov.
Withdrawals reopening	Binance targets Sunday 1 November; no confirmed reopening details as of this revision.	**Target, not fact.** Verify against Binance announcements.
Binance.US affected	"We are a separate, independent platform, and customer funds and services are secure and operating normally."	**Company statement.** Separate entity and custody.

Why the numbers moved

Revision 1.0 reported $5.5–5.9B because that was the range of gross on-chain tallies available in the first six hours. TRM's later reconstruction — tracing the XRP Ledger, Solana, Base and Polygon legs that early tallies under-counted — settled on $6.36B, which Binance's own $6.34B provision effectively corroborates. The lesson generalises: **first-hour outflow estimates on multi-chain thefts undercount, because analysts find the chains they thought to look at first.** Here the very first chain touched, XRP, was the one least discussed on the night.

3 Timeline of the incident

All times UTC. The attack began on 29 October; corporate and state responses ran through 1 November. Sequence reconstructed from TRM Labs, Blockaid and Binance's own updates.

28 Oct, morning (T−36h)
Financing. An attacker-controlled wallet (`0x7C8601d4645b93cea45F71e118A729332e6B5CA0`) receives three small transfers from Tornado Cash. Preparation ran at least 36 hours.

29 Oct, early
Rehearsal. Malicious contract code is deployed and tested against two fresh Ethereum wallets, then a third, with test funds moved and returned — all of it visible on-chain in advance. The sweeper contract `0x63e842B054Bd624a465454D533C33F573e9c6fAe` is deployed at 15:59.

20:05–20:09 (16:05–16:09 ET)
XRP goes first. Five Binance wallets on the **XRP Ledger** send **233.46M XRP (~$296M)** to a single attacker address — ten minutes before every other chain. Investigators treat this as the canary: it tested whether the withdrawal path worked.

20:10
Transfers begin from Binance wallets on **Solana** and **Optimism**.

20:20 (16:20 ET)
Bitcoin, and the nonce spray. 18,270 BTC (~$1.47B) leaves a Binance wallet, immediately split into 1,000 and 100 BTC batches. Simultaneously a type-4 transaction submits **50 EIP-7702 authorisations** to Binance 14 (`0x28C6c06298d514Db089934071355E5743bf21d60`), one per nonce from 18,914,775 to 18,914,824. Forty-nine are invalid; one matches.

20:22
Tron. 612.7M USDT and 46.4M TRX (~$628M) move to new addresses.

20:24:23
The Ethereum sweep. 167,464 ETH, 1.615B USDT and 63 other tokens go to collection address `0x5227f603C1eE34CE3C06eFe6477003BDfCCB2f8c` in one transaction (~$2.5B). Binance 14 is left holding **1 ETH**. Twenty-four seconds later Binance 16 sends 28,005.6 ETH more.

20:41 → 23:56
A standing drain. Further sweeps at 20:41, 20:59, 21:04, 21:44, 22:39 and 23:56 as fresh assets land in the delegated wallet. It also exercises standing permissions over a separate Binance smart account to move another **823M USDC**.

~21:04 (17:04 ET)
Freezes begin. Tether freezes 975.1M USDT; Circle freezes 823M USDC. Ripple, World Liberty Financial, Paxos and the Arbitrum Security Council follow.

22:22 (18:22 ET)
Binance pauses all deposits and withdrawals, having already paused Solana, XRP and several stablecoin networks. Binance Alpha trading is suspended at 23:06.

23:05 (second wave)
The operation extends to further Binance wallets on **Avalanche** and **Polygon**.

00:30, 30 Oct
$6.36B across ten chains. TRM's tally: Ethereum, Bitcoin, Tron, XRP Ledger, Solana, Arbitrum, Optimism, Base, Avalanche, Polygon — most of it inside roughly 20 minutes.

30 Oct
Attribution and root cause. TRM and Chainalysis attribute the theft to **TraderTraitor** (Lazarus / APT38). The FBI and Secret Service join the probe. Binance links the breach to a **compromised DevOps laptop**, reports no evidence of a leaked key, then discloses "additional points of breach". Binance sets aside **$6.34B** from treasury, futures insurance and SAFU.

31 Oct → 1 Nov
Replenishment and confirmation. Binance reports ~90% of losses covered and ten assets fully backed; a new proof-of-reserves snapshot is taken, with the zk proof requiring 40–50 hours. Withdrawals are targeted to reopen **Sunday 1 November**. The **FBI confirms** North Korea's role and asks DeFi participants to block the relevant BTC, ETH and SOL addresses.

4 How the attack worked: access, then amplification

Two distinct things happened, and conflating them is the main analytical error in early coverage. An **access** failure let the attacker act as Binance's systems. An **Ethereum feature** then turned one accessible wallet into a persistent, self-refilling drain. The first was the breach; the second determined how much of it happened on Ethereum.

4.1 The access path

Binance's stated finding is a **compromised DevOps engineer's laptop**. From that foothold the attacker reached a **service container** and used it to submit unauthorised withdrawal transactions — withdrawals the exchange's own pipeline treated as legitimate because they arrived through the systems that are supposed to produce them. Binance says it has found **no evidence of a leaked wallet private key**, and co-CEO Richard Teng pushed back on the simplest reading: "the attacker did not simply use one engineer's permissions, and this was not a single 'one-click' action. It involved a more complex attack process." Binance later disclosed that it had "uncovered additional points of breach" and was still gathering facts.

This matters because it relocates the control failure. The industry's mental model of exchange security is key custody: HSMs, multisig, cold storage, signing ceremony. This incident suggests the binding constraint is **the endpoint and identity layer in front of the signer**. A key that never leaks is not much comfort if the system that asks it to sign can be driven from a developer's workstation.

> **WHAT THIS DOES NOT EXPLAIN**
>
> EIP-7702 authorisations require valid signatures bound to the account nonce. Whether the attacker obtained those through the compromised host, through misuse of legitimate signing access, or through a further weakness has not been established publicly. Treat any confident account of "how the key was stolen" as speculation — including those published in the first 24 hours.

4.2 The XRP leg came first

The attack did not begin on Ethereum. Between **20:05 and 20:09 UTC**, five Binance wallets on the **XRP Ledger** moved **233.46 million XRP, about $296 million**, into a single attacker address. Solana and Optimism followed within minutes; Bitcoin and Tron by 20:22. The Ethereum sweep at 20:24 was the largest single transaction of the night, not the opening move. Investigators describe the XRP transfer as the canary: it tested whether the withdrawal path worked, ten minutes before the rest of the operation committed.

4.3 The EIP-7702 primitive

An exchange hot wallet on an EVM chain has historically been an **externally owned account**: a plain address with no code, movable only by a valid signature. Everything else — limits, velocity checks, allowlists — lived off-chain, in front of the signing operation.

EIP-7702 (Pectra upgrade, May 2025) changes that. It lets an EOA sign an authorisation naming a contract; once a type-4 transaction carrying it lands, **any** call to the account executes that contract's logic with full access to its balances. The delegation is bound to the account's nonce and **persists** until the account signs something that replaces or clears it. For retail wallets that enables batching, gas sponsorship and session keys.

For a hot wallet holding billions, one valid authorisation hands an attacker **persistent code-level control, including every deposit that arrives afterwards**.

Before this incident, the four known EIP-7702 abuses in H1 2026 totalled roughly $1.08M. Blockaid's H1 report forecast the first seven-figure case before year end. It arrived three orders of magnitude above forecast.

4.4 The nonce spray

Binance 14 was processing withdrawals continuously, so its nonce advanced block by block and the attacker could not know its current value. So he did not guess — he signed **fifty authorisations covering a contiguous nonce window** and packed all fifty into one type-4 transaction. Forty-nine failed. The one that matched made the delegation live at a moment when Binance's own transactions were still flowing from the same address, which made the drain look like ordinary exchange activity to a casual monitor.

> **WHY THIS OUTLIVES BINANCE**
>
> Nonce unpredictability is not a security control. An attacker with signing access can cover a nonce window cheaply. The only controls that hold are **policy enforcement before a signature exists** and **continuous monitoring of every hot-wallet address for code changes**, with a revocation transaction prepared in advance.

4.5 A standing drain across ten chains

The delegation was not a one-shot. After the initial sweep of 167,464 ETH and 63 tokens, the attacker swept again at **20:41, 20:59, 21:04, 21:44, 22:39 and 23:56 UTC** as fresh assets landed. The delegated wallet also exercised its standing permissions over a *separate* Binance smart account to move another **823 million USDC**, and a second wave around 23:05 extended the operation to wallets on **Avalanche and Polygon**. By 00:30 on 30 October TRM had traced roughly $6.36B across Ethereum, Bitcoin, Tron, XRP Ledger, Solana, Arbitrum, Optimism, Base, Avalanche and Polygon.

4.6 Laundering and detection

Proceeds were split — 18,270 BTC broken immediately into 1,000 and 100 BTC batches, later spread across 19 wallets — swapped through decentralised venues, and borrowed against: $60M USDT supplied to Aave to borrow roughly 19,762–19,800 ETH, converting freezable stablecoins into unfreezable ETH. Aave froze DAO-operated markets, ultimately across 16 networks, and the Arbitrum Security Council froze 8,426 ETH and 74.6M ARB (~$30.5M). Blockaid's detection fired under two minutes after the first sweep, before any public report, and identified the key-compromise and delegation mechanism within eleven minutes. That is close to the ceiling of what detection can do — and it still arrived after 167,464 ETH had left. Detection is not prevention.

5 The money: estimates, freezes, and what is still loose

TABLE 2 — LOSS ESTIMATES, FIRST 72 HOURS

Source	Figure	Basis
TRM Labs	**$6.36B**	Full reconstruction across ten blockchains, finalised 30 Oct; the figure the industry has converged on. ~4x Bybit.
Binance (provision)	**$6.34B**	Company funds set aside to cover losses — effectively corroborates TRM's scale.
Chainalysis	$5.9B	Early estimate; also produced the attribution.
Arkham Intelligence	$5.8B	Entity-explorer tally at 20:00 UTC on 29 Oct, before the XRP and later legs were counted.
Kairos Research	$5.7B	Hot-wallet accumulations.
Decrypt tally	$5.57B	Three-chain breakdown: ETH + BTC + Tron only.
Blockaid	≥$5.5B	Six-chain view, described as ongoing at publication.
Glassnode	~$5.3B	Most conservative third-party figure.

The early spread is itself the finding: tallies published within six hours ranged across $600M and systematically omitted chains. TRM's $6.36B and Binance's $6.34B now agree to within a rounding error.

5.1 Frozen, by issuer

Issuer / body	Frozen	Mechanism
Tether (USDT)	>$1.567B	Contract-level blacklist of receiving addresses.
Circle (USDC)	>$823M	Contract-level blacklist, coordinated with law enforcement.
Ripple (RLUSD)	~$200M	Credited by Binance co-CEO Yi He.
World Liberty Financial (USD1)	~$27M	Reported by co-founder Zach Witkoff.
Paxos (PAXG)	>$8M	1,906.67 PAXG disclosed.
Arbitrum Security Council	~$30.5M	8,426 ETH + 74.6M ARB frozen by governance action.
Total (TRM)	**~$2.7B**	Stablecoin issuers plus the Arbitrum council.

> **FROZEN IS NOT RECOVERED**
>
> A freeze blocks movement from an address; it does not return tokens to Binance. Recovery needs a court order compelling an issuer to burn and reissue, or a negotiated resolution. Until then the assets sit in limbo — and Binance must fund the shortfall from its own balance sheet in the meantime, which is exactly what the $6.34B provision is for.

5.2 What the attacker still holds

TRM's assessment: more than **420,000 ETH** and **18,270 BTC** remain outside any issuer's reach — roughly **$2.4 billion**. The 18,270 BTC was split within minutes into 1,000 and 100 BTC batches and later distributed

across 19 wallets. None of it can be frozen by anyone. Recovery of this tranche depends entirely on attribution leading to people and infrastructure, which is why the FBI confirmation and any sanctions designations matter more than the freeze totals.

5.3 Historical scale

Incident	Loss	Attribution / note
Binance, Oct 2026	$6.36B	TraderTraitor (DPRK). Compromised employee host + EIP-7702 amplification. Ten chains.
Bybit, Feb 2025	~$1.5B	TraderTraitor. Cold-wallet signing UI compromise.
Coincheck, 2018	~$534M	NEM from hot wallets.
Mt. Gox, 2014	~850k BTC	Custody failure and insolvency, not a single event.
Binance, 2019	~$40M	7,000 BTC. The comparison Binance would prefer.

That the same unit is behind both the largest and the second-largest exchange thefts in history, eighteen months apart, is the single most important fact in this report for anyone operating an exchange. The controls Bybit tightened were not sufficient.

6 The reserve-backing problem

The most consequential early disclosure was not the loss figure — it was *which* wallets were drained. Binance publishes a monthly list of wallets it controls and what they hold, and compares those totals against customer liabilities. CoinDesk's review found that **the addresses emptied on 29 October are the same addresses Binance lists as backing customer assets**. On 1 October, Binance's disclosed ether reserve ratio was exactly 100%, with USDC at 108.26%. The roughly **204,500 ETH** taken therefore left disclosed ETH backing about **6% short** until the exchange replaced what was stolen.

> **TWO IMPLICATIONS THAT OUTLAST THE HEADLINE NUMBER**
>
> **1. Separation failed.** Proof-of-reserves wallets are supposed to be the least reachable assets on an exchange. Here they were the payment float. An exchange that uses reserve-attested addresses as hot wallets is publishing a solvency claim about accounts it is simultaneously spending from.
>
> **2. The shortfall is a market event, not just an accounting one.** Replacing ~204,500 ETH means real spot demand against a falling market, which is a reason to watch Binance's on-chain refill behaviour rather than its statements.

6.1 What Binance actually did about it

The follow-through, tracked across four public updates, is more substantive than most post-breach disclosures:

- **A $6.34B provision**, funded from corporate treasury, the **SAFU** emergency reserve and **futures insurance reserves**. Binance said it rebalanced only excess insurance reserves, leaving required regulatory balances intact, and committed to restoring SAFU to roughly $1 billion.
- **~90% of stolen assets replaced** by 31 October (up from ~80% at the prior update).

- **Ten assets declared 100% backed:** BTC, ETH, USDT, BNB, SOL, USDC, XRP, USD1, RLUSD and ZEC.
- **The residual 10% is concentrated in less liquid tokens**, being sourced through market and OTC channels. Binance: "We will continue to buy the remaining relevant token assets… Binance will absorb the financial impact of these stolen funds, not our users."
- **A new proof-of-reserves snapshot** taken at midnight UTC on 31 October, published through its PoR system.
- **Withdrawals targeted to reopen Sunday 1 November.**

6.2 The verification gap is the story

None of the above is yet independently checkable by a customer, and the reason is mechanical: generating the zero-knowledge proof behind Binance's reserve attestation takes **40 to 50 hours**. Holders of the ten named tokens are expected to be able to verify minimum 1:1 backing from roughly **3 November** — several days after withdrawals are supposed to reopen.

So the sequence a depositor actually faces is: withdrawals resume, *then* the proof lands. That ordering is not sinister, but it does mean the reopening is being asked for on trust. And it illustrates the structural weakness of monthly-snapshot reserve attestation: a proof generated on 31 October describes the exchange at a moment that is already two days old by the time it can be verified. It cannot detect a liability that moves in between — which is precisely what a run on the exchange is.

> **WHAT A BETTER ATTESTATION WOULD HAVE TO DO**
>
> Report liabilities and assets continuously rather than monthly; disclose whether attested addresses are also signing hot wallets (the question this incident was made of); and publish a standing list of delegated EIP-7702 accounts so customers can distinguish a reserve address from an operating one.

6.3 The reflexivity problem with BNB

BNB is both a tradable asset and a claim on the exchange whose solvency was in question. It fell roughly 6–9% on the day, worse than BTC or ETH — the market pricing exactly that double exposure. Comparisons to FTX's FTT are sloppy (BNB is not a pure internal IOU, Binance is a profitable going concern, and there is no evidence of misappropriated customer funds), but the direction of the reflexivity is real, and it is why BNB underperformed. The successful $6.34B provision is what kept the parallel from going further.

7 Response: Binance, issuers, DeFi, law enforcement

7.1 Binance — sequence and significance

The messaging arc is itself informative. From ~20:30 to ~23:00 UTC Binance maintained a narrow statement about "reports of a potential security issue" with no confirmed impact to user funds, even as CZ was publicly saying it looked like a hack. Only after the last hot wallet drained did the exchange suspend all deposits and withdrawals. Note that the full halt came *after* the funds were already gone: withdrawal pauses protect a remaining balance, they do not recover a swept one, and in this case the sweeper was configured to forward inbound transfers — so leaving deposits open was actively harmful while the delegation stood.

- **23:22 UTC** — disputed the $1.8B figure publicly, asserting $2.54B frozen. Unusual and, in this narrow sense, helpful: it put a falsifiable number on the record.

- **00:04 UTC** — Yi He: funds safe, all losses covered, full post-mortem to follow, "rely only on official Binance channels".
- **Anti-phishing warning** issued in the first statement — appropriate, and the single most useful thing Binance said all evening for ordinary users.
- **Since disclosed:** the loss figure ($6.34B provision), the root cause (compromised DevOps laptop), attribution (TraderTraitor), replenishment progress (~90%), and a proof-of-reserves timetable.
- **Still not said:** how the 7702 authorisations were obtained, what the "additional points of breach" are, whether reserve and hot wallets remain co-located, and the per-network reopening plan.

7.2 Stablecoin issuers

Tether, Circle, Ripple, World Liberty Financial and Paxos all froze within hours, collectively >$2.6B by some tallies and $2.54B by Binance's own count. This is the most effective cross-industry response in the history of exchange breaches — and it is also an uncomfortable demonstration of centralised power: five private companies decided, in a few hours and at scale, that specific addresses could no longer transact. Whatever one thinks of that power, the practical lesson is that **stablecoin holdings are freezeable by design and native assets are not**. An attacker who understands this converts to ETH immediately; the operator here was doing exactly that when Aave markets were frozen.

7.3 DeFi

- **Aave** froze all DAO-operated V3 and V4 markets as a precaution. Contracts unaffected, positions overcollateralised, withdrawals and repayments still permitted. This stopped the attacker from borrowing further against laundered collateral.
- **Arbitrum Security Council** executed an on-chain freeze of ~$30.5M — a governance body using emergency powers against an address, which will be cited in future debates about L2 admin keys.
- DEX venues processed the attacker's swaps. There is no general mechanism to reverse a completed DEX trade.

7.4 Law enforcement

This has moved faster than the usual multi-week pattern. The **Secret Service and FBI joined the probe** within a day, and on **1 November the FBI confirmed North Korea's role** and asked the DeFi community to block the associated BTC, ETH and SOL addresses — an unusually direct public request, and a signal that the $2.4B unfrozen tranche is the priority. Circle and Binance both cited law-enforcement coordination for their freezes. OFAC designations on the 19 BTC wallets and the ETH clusters are the logical next step; sanctions convert attribution into legal force against venues and mixers that touch the funds.

7.5 Remediation funding

Binance's coverage draws on three sources: **corporate treasury**, **futures insurance reserves** (rebalanced from excess only, per Binance, leaving regulatory balances and internal risk coverage intact), and **SAFU**, the Secure Asset Fund for Users, which Binance committed to restore to roughly $1 billion. Binance's public SAFU bitcoin address is monitored on-chain, so the refill is observable rather than merely asserted — the one part of the remediation a third party can watch in real time.

7.6 Context: a bad day for exchange security

Polymarket suspended trading the same day after a third-party vendor breach led to user losses. Two unrelated incidents on one day is not proof of a coordinated campaign, but it is a reminder that the *supply chain* around exchanges — vendors, signing infrastructure, oracles, bridges — is where the leverage is. Neither incident involved breaking cryptography.

8 Market impact

The market reaction was severe but orderly — a de-risking move, not a liquidation cascade of the kind that followed FTX. Prices below are snapshots from 29–30 October 2026 and moved throughout the evening; they are illustrative of direction and magnitude, not closing marks.

TABLE 3 — PRICE REACTION (APPROXIMATE, INTRADAY 29 OCT 2026)

Asset	Level	Change	Read
Bitcoin (BTC)	~$77,000–79,000	−2.7% to −3.6%	Broke below $79,000; the headline risk gauge.
Ether (ETH)	~$2,206–2,268	−3.6% to −6.2%	Directly implicated chain; largest stolen notional.
BNB	~$690–708	−6% to −9%	Worst large-cap. Exchange-equity reflexivity.
Solana (SOL)	~$94	−5.7% to −8%	Fell through $100; withdrawal pause amplified.
XRP	~$1.21	−5.8% to −8.1%	XRP Ledger withdrawals were paused.
Tron (TRX)	~$0.35	+7.3% to +8.7%	Odd strength; Tron was a laundering route, not a victim chain for freezes.
Monero (XMR)	~$616–637	+3% to +6%	Privacy-coin bid — the market's read on laundering demand. Echoes the +51% move after a 2025 theft.
Hyperliquid (HYPE)	~$90	+12% to +14%	Rotation into a venue perceived as uncorrelated with the compromised one.

8.1 What the price action is telling you

- **This was priced as a counterparty event, not a technology event.** BTC and ETH fell a few percent; BNB, SOL and XRP — the assets whose *off-ramps* were disrupted — fell twice as much. Markets repriced access, not blockchains.
- **Privacy coins catching a bid is a laundering-demand indicator.** It is not a signal about XMR's fundamentals.
- **Venue rotation toward HYPE and TRX is a measure of distrust in Binance custody specifically**, not in crypto generally.
- **No systemic contagion yet.** Stablecoin pegs held (USDT ~$0.9985). No major lender reported impairment. Aave froze instead of absorbing. That is the difference between this and 2022.

> **THE TRADING STRUCTURE WORTH WATCHING**
>
> When withdrawals are halted at a major venue, that venue's prices decouple from the rest of the market — crypto stuck inside trades at a discount (or premium) to crypto you can actually move. Watch the **Binance-vs-elsewhere basis on BTC and ETH**: it is the market's live estimate of the probability and duration of the withdrawal freeze. A widening discount says traders expect the freeze to last; convergence says they expect resumption. It is a cleaner sentiment gauge than the spot price.

9 Best practices

Ordered by how soon they matter. Section 9.1 is for anyone with a Binance account right now; the rest is durable practice.

9.1 Immediately, if you have funds on Binance

1. **Do not rush a withdrawal to an unverified destination.** The most common way people lose money during an exchange incident is a panicked transfer to a wrong network or a mistyped address. Stuck-in-queue is recoverable; sent-to-the-wrong-chain usually is not.
2. **Confirm network support before you send.** Binance's own status page was showing Bitcoin and Ether withdrawal routes open while the exchange's broader statement said all deposits and withdrawals were suspended. The statement is authoritative; per-network indicators lag. If a route is marked "wallet maintenance" or "hot wallet being refilled", treat it as closed.
3. **Send a test amount first.** One extra fee buys protection against a typo, a wrong chain, or a destination that doesn't support the asset. This is not the moment to optimise fees.
4. **Assume you are now a phishing target — because you are.** Breach events produce a reliable wave of fake "Binance recovery", "security verification", "unlock your withdrawal" emails, SMS, DMs and paid-ad search results. Binance will not DM you first, will not ask for your password, 2FA code or seed phrase, and will not ask you to "verify" to release funds. Navigate by typing the domain or using the app — never through a link in a message.
5. **Beware fake support on social media.** Replies offering to "escalate your case" from accounts with Binance logos and slightly wrong handles are the highest-yield scam of the next 72 hours.
6. **Don't publish screenshots** of balances, transaction IDs, or account pages. They carry account identifiers and make you a better-targeted phishing mark.
7. **Check where your assets actually sit.** Spot balance, Earn/staking, futures margin, Binance Alpha and Simple Earn are different claims with different unwind mechanics under stress. Know which you're in before you need to move.
8. **If withdrawals are closed, do not chase it with leverage.** Opening a hedge you can't close on the same venue deepens exposure to the thing you're worried about.

9.2 Durable counterparty hygiene

- **Size your exchange balance to your trading need, not your net worth.** An exchange balance is an unsecured claim on a private company. Keep the working float there; keep savings in self-custody.
- **Diversify venues.** Not because other exchanges are safer in the abstract, but because a halt at one venue should not stop you from trading or exiting.

- **Read proof-of-reserves disclosures for the right thing.** After this incident, the question is no longer "what is the ratio" but **"are the attested addresses also the operating hot wallets?"** A 100% ratio is worthless if the reserve addresses sign daily payments.
- **Treat stablecoins as freezeable.** USDT and USDC can be blacklisted at the contract level by their issuers. That protects you in a theft; it is also a reminder that they are permissioned instruments, not bearer assets.
- **Pre-stage your exit.** Know, in advance, which network you'd withdraw on, to which address, and have that address already whitelisted and tested. Deciding this during a halt is how mistakes happen.

9.3 Self-custody and DeFi users — the EIP-7702 checklist

EIP-7702 changed what an EOA *is*. A wallet you control can now be running someone else's code without your knowledge if you ever signed a malicious delegation, or if a dApp you interacted with tricked you into one. Practical hygiene:

- **Check your addresses for delegation.** Etherscan surfaces delegated accounts, and revocation tools (Revoke.cash and equivalents) now include 7702 delegations alongside token approvals. Any delegation you did not deliberately create is an emergency.
- **Clear unknown delegations before anything else.** Clear the delegation first, then rotate keys, then move funds. Moving funds out of a still-delegated wallet can be intercepted by the delegated code.
- **Never sign an authorisation you can't read.** A 7702 authorisation is a durable grant of code execution over your account. It is categorically more dangerous than a token approval.
- **Separate keys by purpose.** A hot trading key, a DeFi key, and a savings key should be different keys in different wallets. One compromise should cost you one bucket.
- **Revoke approvals on a schedule.** Quarterly, and immediately after any protocol you've used is exploited.
- **Use hardware signing for anything above your pain threshold**, and verify the destination address on the device screen, not on the computer's display.

9.4 If you operate wallets that hold other people's money

This is the section that would have prevented the incident.

- **Treat EIP-7702 authorisations as privileged operations** — the same approval tier as a cold-wallet transfer, not as a user convenience. Route them through policy review.
- **Enforce policy *before* the signature exists.** Pre-sign simulation of the resulting state change, destination allowlists, and amount anomaly detection against a rolling 30-day baseline. Post-hoc monitoring is an incident-response tool, not a control.
- **Monitor every hot-wallet address for code changes**, and keep a signed revocation transaction prepared in advance so clearing a delegation is one broadcast away.
- **Hold no inventory in an address whose delegation status is unknown.**
- **Do not co-locate reserve or proof-of-reserves inventory with payment float.** Use separate addresses, separate keys, separate signing infrastructure. This single change would have capped the loss at the working balance of one wallet.
- **Cap the blast radius of any single key.** If one key can move $2.5B, that key is the control. Withdrawal hot wallets should hold hours of float, not months.
- **Assume key compromise, not key secrecy.** Design so a leaked key costs you a bounded amount, detected in minutes, rather than an unbounded amount detected after the fact.

- **Nonce windows defeat nonce unpredictability.** Don't rely on an attacker being unable to guess your transaction counter.
- **Have a freeze playbook with issuers.** The difference between a $5.7B theft and a $2.9B theft tonight was phone numbers that existed before the incident. Pre-negotiate escalation paths with Tether, Circle and the other issuers of every stablecoin you hold.
- **Publish the post-mortem.** The industry learns from these only if the details are public; silence converts one incident into many.

10 Resources to monitor

Ordered by signal quality for this specific incident. Primary sources first — social posts from named researchers and issuer CEOs moved faster and were more accurate than most news coverage in the first six hours.

10.1 Official Binance channels (the only authoritative word on withdrawals)

- **Binance announcements** — binance.com/en/support/announcement. The per-network deposit/withdrawal status list lives here; it is the thing to check before attempting a transfer.
- **@binance** on X — the verified account. Statement cadence has been roughly hourly during the incident.
- **@heyibinance** (Yi He, co-founder & co-CEO) — posted the "cover all losses" commitment and is the source for the post-mortem promise.
- **@cz_binance** (Changpeng Zhao) — no longer management, but majority shareholder; his language has been ahead of the company's.
- **Binance status / support pages** — for network-level "wallet maintenance" notices.
- **@BinanceUS** — separate entity; relevant if you hold there.

10.2 On-chain: verify, don't trust

TABLE 4 — ADDRESSES CENTRAL TO THE INCIDENT

Role	Address
Binance 14 (delegated hot wallet)	`0x28C6c06298d514Db089934071355E5743bf21d60`
Binance 16 (second drained)	`0xDFd5293D8e347dFe59E90eFd55b2956a1343963d`
Collection address	`0x5227f603C1eE34CE3C06eFe6477003BDfCCB2f8c`
Attacker sweeper contract	`0x63e842B054Bd624a465454D533C33F573e9c6fAe`
Operator (Tornado-funded)	`0x7C8601d4645b93cea45F71e118A729332e6B5CA0`

- **Etherscan** — watch Binance 14 for a delegation-clearing transaction (a type-4 auth replacing the sweeper) and for refill activity. Both are leading indicators of recovery posture.
- **Arkham Intelligence** — entity-level explorer; it was the first to put a dollar figure on illegitimate withdrawals, and its Binance entity page aggregates all labelled wallets.
- **ZachXBT** (@zachxbt) — the most reliable independent freeze tally.

- **Spreek** (@spreekaway) — flagged the drain first.
- **Conor Grogan** (@jconorgrogan, Coinbase) — early independent sizing; consistently careful about gross vs net.
- **Blockaid** (blockaid.io/blog) — published the detailed technical incident report including the nonce-spray mechanics. Best single technical document available.
- **Chainalysis, TRM Labs, Elliptic** — attribution and sanctions exposure when it comes; their blogs are where attribution will actually appear.

10.3 Issuer freeze trackers

- **@paoloardoino** (Tether CEO) and **@jerallaire** (Circle CEO) — freeze confirmations come from these accounts first, before any press coverage.
- **Tether transparency / frozen-address disclosures** — for the cumulative USDT freeze total.
- **@Paxos**, **@Ripple** — smaller freezes but part of the running total.

10.4 Newsrooms worth reading (and their RSS feeds)

Outlet	Why	Feed
Protos	Ran a live blog from the first hour; timestamped, skeptical, no hype.	`protos.com/feed/`
The Block	Fastest to precise on-chain numbers with attribution.	`theblock.co/rss.xml`
CoinDesk	Broke the reserve-wallet analysis — the most consequential story of the night.	`coindesk.com/arc/outboundfeeds/rss/`
Cointelegraph	Live-updates page is updated continuously.	`cointelegraph.com/rss`
Decrypt	Clean on-chain tallies with per-chain breakdowns.	`decrypt.co/feed`
BleepingComputer	Security-reporting rigor; good on the mechanics.	`bleepingcomputer.com/feed/`
CryptoSlate	Aggregates issuer statements quickly.	`cryptoslate.com/feed/`
BBC / AP / Reuters / Guardian	Non-crypto-native verification; useful for what a mainstream reader will believe.	—

10.5 Free monitoring tools

- **RSS reader** (Feedly, Inoreader, NetNewsWire) — subscribe to the six feeds above; that is the cheapest complete coverage available.
- **Google Alerts** — set for "Binance hack", "Binance post-mortem", "Binance withdrawals resume". Free, email-based, no account risk.
- **Etherscan address watch** — email/Twitter alerts on any movement from the five addresses in Table 4.
- **DeFiLlama hacks dashboard** and **rekt.news leaderboard** — running totals that get corrected as figures settle; better than any single news article a week from now.
- **Revoke.cash** — check and clear token approvals and 7702 delegations on your own addresses.
- **Chainabuse** — community reporting of scam addresses; useful for screening "recovery service" offers.
- **This project's tracker** — nwfella.github.io/binance-hack-dossier — rebuilds hourly from the feeds above, free, no account.

A NOTE ON "RECOVERY SERVICES"

After every large theft, a market appears for people who claim they can recover stolen funds for a fee. For an individual user, there is nothing to recover from this incident unless Binance fails to honour its coverage pledge — in which case the route is Binance support, then a regulator or court, not a paid stranger on Telegram. Legitimate forensic firms (Chainalysis, TRM, Elliptic) work for exchanges, issuers and law enforcement, not for retail claimants.

11 What to watch next

Revision 1.0 listed attribution and the post-mortem as the things to watch. Attribution is now settled by the FBI; the operational questions are the live ones.

TABLE 5 — LEADING INDICATORS AND WHAT EACH WOULD TELL YOU

Event to watch	Where	What it would mean
Withdrawals actually reopen (targeted 1 Nov)	Binance announcements	The single clearest solvency signal available to a retail user. A staged reopening (small coins first) suggests liquidity strain; a clean full reopening suggests the provision is real.
Proof-of-reserves verification goes live (~3 Nov)	binance.com/en/proof-of-reserves	Whether the 1:1 claim on ten assets holds up under customer verification. A slipped date or a partial set would be significant.
The remaining 10%	Binance incident updates on X	Whether illiquid-token sourcing completes, and at what cost. Persistent failure to reach 100% would keep the reserve question open.
"Additional points of breach"	Binance / Richard Teng statements	Whether the compromise was wider than one laptop — the difference between an endpoint failure and a systemic one.
OFAC sanctions on the 19 BTC wallets and ETH clusters	sanctionssearch.ofac.treas.gov	Converts attribution into legal force, and pressures venues and mixers that touch the funds.
Movement from the 18,270 BTC / 420,000 ETH	Chainalysis, TRM, Arkham	The $2.4B tranche is the only part still recoverable by tracing. Movement is both a laundering signal and an investigative opening.
Customer verification of delegation states	Etherscan, Revoke.cash, exchange engineering blogs	Whether the industry adopts the two controls that would have capped this: pre-signature policy and hot-wallet delegation monitoring.
Follow-on EIP-7702 abuses	Blockaid, BlockSec, Phylax, rekt.news	The technique is public and proven at scale. Expect copycats against venues with weaker pre-sign controls.
Regulatory and political aftermath	CFTC, SEC, congressional hearings	The CFTC chair used this to argue offshore exchanges need US oversight; the incident became a pre-election flashpoint. Watch whether reserve attestation becomes a rule rather than a marketing practice.

Event to watch	Where	What it would mean
Exchange-flow and ETF data	Farside, CoinShares, Glassnode	Bitcoin ETFs lost $643M, ending a four-day inflow run, and institutions pulled exchange balances. Sustained outflows would confirm the incident changed custody behaviour, not just prices.

> **THE QUESTION THAT STILL DECIDES THE OUTCOME**
>
> Not how much was stolen — that is now well established at ~$6.36B. It is **whether the replenishment is real, verifiable and complete, and whether withdrawals reopen on the stated timetable without impairing anyone else.** Binance has put its own balance sheet behind the answer, which is more than most exchanges have done. But the proof will not exist until holders can check it.

11.1 Provisional assessment

On the evidence available: the technical sequence is unusually well documented; attribution is now government-confirmed; the financial remediation is substantial and partly verifiable within days; and the industry response — ~$2.7B frozen, Aave markets frozen across 16 networks, Arbitrum council action, detection in under two minutes — was materially better than in any prior comparable incident. The failure was not detection, and not liquidity management. It was **architecture**: reserve inventory co-located with payment float, reachable through an employee workstation, and a wallet that one valid authorisation could turn into a permanent drain.

12 Methodology, sources, disclaimer

12.1 Method and revision history

Revision 1.1, 1 November 2026. Incorporates: TRM Labs' full $6.36B ten-chain reconstruction; the FBI confirmation of North Korea's role; Binance's root-cause disclosure (compromised DevOps laptop, no key leak evidence, additional points of breach); the $6.34B provision and 90% replenishment; and the state of the pending reserve proof. Sections 1, 2, 4, 5, 6 and 11 were substantially rewritten; the cover and two charts of figures were replaced.

Revision 1.0, 29 October 2026, 18:45 PDT. Compiled within roughly seven hours of the first sweep from primary reporting and on-chain analysis. Stated a $5.5–5.9B loss range, no attribution, and a likely leaked private key as root cause.

What changed between revisions, and why it matters. Two of revision 1.0's central judgements were wrong: the loss figure (undercounted because early tallies missed the XRP, Solana, Base and Polygon legs) and the root cause (a key leak, which Binance's own investigation does not support). Attribution was absent because no firm had published it yet. All three are corrected here, and the corrections are stated rather than silently edited — first-hour reporting on thefts of this size should be read as a floor, not an estimate.

Claim handling: where independent parties publish conflicting figures, both are shown with attribution rather than reconciled into one number. Claims sourced only to social media are labelled. Transaction hashes and addresses come from Blockaid's report and are reproduced so a reader can verify rather than trust.

12.2 Primary sources

- **TRM Labs** — "North Korea steals USD 6.36 billion from Binance in the largest hack in history". The definitive reconstruction: preparation timeline, per-chain sequencing, freeze totals, unattributed holdings, attribution.
- **Chainalysis** — attribution to TraderTraitor with "high degree of confidence".
- **FBI** — confirmation of North Korea's role and request to block BTC/ETH/SOL addresses (1 Nov), via CoinDesk.
- **Binance** — incident updates, statements by co-CEOs Richard Teng and Yi He, the $6.34B provision, replenishment progress, and the proof-of-reserves snapshot.
- **BleepingComputer** (L. Abrams) — the DevOps-laptop root cause and the "no key leak" finding.
- **Blockaid** — technical incident report: sweeper contract, 50-authorisation nonce spray, per-chain movements.
- **CoinDesk** — the reserve-wallet analysis; the 90% replacement report; FBI confirmation.
- **CryptoSlate** — the XRP-first sequencing ($296M, 233.46M XRP) and the sweep schedule.
- **Bitcoin.com News** — the fully-backed asset list, SAFU and futures insurance mechanics, PoR verification timeline.
- **Decrypt, The Block, Protos, Cointelegraph, Al Jazeera, BBC, AP, Guardian** — mainstream and trade confirmation of core facts, market reaction and policy response.
- **On-chain** — Etherscan, Arbiscan, Snowscan, Optimistic Etherscan, Arkham Intelligence.
- **Named researchers** — Spreek (first flag), ZachXBT, Wazz Crypto, Conor Grogan, Derek Chiang, Paolo Ardoino, Jeremy Allaire, Aave.

12.3 Disclaimer

This document is a research summary compiled from public sources. It is **not** financial, legal or investment advice, and not an independent forensic audit. Binance's root-cause account is a company finding about its own systems and has not been independently verified; its "additional points of breach" remain undisclosed. The replenishment figures are company statements not yet checkable against a published proof. Withdrawals had not resumed at the time of writing, and the 1 November target could slip. Nothing here should be read as a finding of fact about Binance's solvency, its internal controls, or the identity of individuals involved. Verify anything you intend to act on against a primary source in section 12.2.

Companion resource. A live tracker at **nwfella.github.io/binance-hack-dossier** rebuilds hourly at :05 from public RSS feeds and the on-chain references in section 10. It makes no AI/LLM calls, requires no account, and states its own age — if the scheduled refresh stalls, the page says so rather than going quietly stale.

Revision 1.1 · 1 November 2026. Compiled by nwfella.